

Security Rules & Compliance Document

The complete access-control rules, a production security checklist, and the four legal pages Raj Raani Collections needs live before a payment gateway or a customer will trust it.

Brand	Raj Raani Collections
Covers	Firestore & Storage rules, password/OTP security, threat checklist, DPDP Act, Terms, Privacy, Shipping, Refund
Before publishing	Sections 08–11 are templates — fill every [bracket] and have them checked by a professional before they go live

01

How security actually works here

There is no separate "security layer" bolted onto the app — access control lives in two rule files that Firestore and Cloud Storage enforce on every single request, whether it comes from the app, a browser's dev console, or an attacker who found the public API config. The rule, stated once: **deny by default, then open exactly what is needed**. Every collection below is either public-read, owner-only, or admin-only — nothing is left at its permissive default.

02

Firestore Security Rules — complete

```

rules_version = '2';
service cloud.firestore {
  match /databases/{database}/documents {

    function isAdmin() {
      return request.auth != null && request.auth.token.admin == true;
    }
    function isOwner(uid) {
      return request.auth != null && request.auth.uid == uid;
    }
    function isSignedIn() {
      return request.auth != null;
    }

    // Catalog -- public read, admin write
    match /categories/{id}      { allow read: if true; allow write: if isAdmin(); }
    match /products/{id}       { allow read: if true; allow write: if isAdmin(); }
    match /productVariants/{id} { allow read: if true; allow write: if isAdmin(); }

    // Per-user data -- owner or admin only, nested subcollections inherit
    match /users/{uid} {
      allow read, write: if isOwner(uid) || isAdmin();
      match /{sub=**} {
        allow read, write: if isOwner(uid);
      }
    }

    // Orders -- the owning customer can read their own; only the
    // server (Admin SDK, via Server Actions) or an admin can write
    match /orders/{id} {
      allow read: if isAdmin() ||
        (isSignedIn() && resource.data.userId == request.auth.uid);
      allow create: if true; // guest checkout -- validated server-side
      allow update: if isAdmin();
      allow delete: if false; // orders are never deleted, only cancelled
    }

    // Audit trails -- admin only, and never editable once written
    match /stockLogs/{id} {
      allow read: if isAdmin();
      allow create: if isAdmin();
      allow update, delete: if false;
    }
  }
}

```

```

    }

    // Assistant transcripts -- anyone can append to their own session,
    // only the admin can read them back
    match /assistantLogs/{id} {
      allow read: if isAdmin();
      allow create: if true;
      allow update, delete: if false;
    }

    // Deny everything else explicitly
    match /{document=**} {
      allow read, write: if false;
    }
  }
}

```

03

Cloud Storage Security Rules

```

rules_version = '2';
service firebase.storage {
  match /b/{bucket}/o {

    // Product photos -- public read, admin write, images only, size-capped
    match /products/{allPaths=**} {
      allow read: if true;
      allow write: if request.auth != null
        && request.auth.token.admin == true
        && request.resource.size < 5 * 1024 * 1024
        && request.resource.contentType.matches('image/.*');
    }

    // Category banners -- same pattern
    match /categories/{allPaths=**} {
      allow read: if true;
      allow write: if request.auth != null
        && request.auth.token.admin == true
        && request.resource.size < 5 * 1024 * 1024
        && request.resource.contentType.matches('image/.*');
    }

    // Deny everything else explicitly
    match /{allPaths=**} {
      allow read, write: if false;
    }
  }
}

```

Redeploy after every change

Rules are not synced automatically from app code. After any change to either file: `firebase deploy --only firestore:rules,storage:rules`. Test changes against the Firebase emulator's rules unit-testing tools before deploying to production — a rules bug fails silently as "permission denied" in the app, which is easy to misdiagnose as an app bug instead.

04

Password & OTP security

CONTROL	SETTING
Minimum password length	8 characters minimum -- Firebase's default of 6 is too weak; raise it in Authentication -> Settings -> Password Policy
Password complexity	Require at least one uppercase, one lowercase and one number via the same Password Policy screen
OTP delivery	Firebase-managed SMS with invisible reCAPTCHA; add Firebase App Check to block scripted OTP-request abuse
OTP expiry	Firebase-issued codes are single-use and time-limited by default -- do not build a custom, longer-lived code
Session length	Customer session cookies: 7-14 days. Admin session cookies: 24-72 hours, with re-authentication required before a destructive action like a bulk delete
Account recovery	Firebase Auth's own reset-email flow only -- never a custom 'security question' fallback, which is weaker, not stronger
Brute-force protection	Firebase Auth throttles repeated failed sign-ins automatically; App Check adds a second layer against scripted attempts

05

Production security checklist

Access control

- Firestore and Storage rules deployed exactly as in sections 02-03, tested against the emulator, not just "looks right"
- Admin access granted only via a custom claim set server-side -- never a client-writable field
- Every admin route re-checked in Next.js middleware on every request, not cached client-side

Secrets

- No secret, ever, in a `NEXT_PUBLIC_` variable -- audited against the table in the Backend & Authentication Document
- Service-account JSON and `.env` files listed in `.gitignore` before the first commit
- Firebase App Hosting environment configuration is the only place production secrets are typed in

Input & sessions

- Every Server Action validates its input with a schema (Zod) before touching Firestore
- Session cookies are httpOnly, secure, sameSite -- confirmed with browser dev tools, not assumed
- Rate limits in place on sign-in, checkout, the Excel import, and the AI assistant

Payments & webhooks

- No card or bank detail ever stored on this server -- Razorpay's hosted Checkout.js handles all of it
- Razorpay and Shiprocket webhook signatures verified before any payload is acted on
- Payment status changes only through a verified webhook or a signature-checked callback, never a plain client POST

Monitoring & recovery

- Firestore scheduled exports to Cloud Storage turned on, and a restore actually tested once
- Firebase console and App Hosting logs checked weekly for repeated auth failures or error spikes
- A named person (even if it's just the owner) knows what to do first if a customer reports account or payment fraud

06

Can this be hacked? — threat to mitigation

IF SOMEONE TRIES TO...	WHAT STOPS THEM
Read another customer's address or order	Firestore rules check resource.data.userId against the caller's own auth token -- enforced by Firestore itself, not app code that could have a bug
Grant themselves the admin role	Custom claims can only be set by code holding the service-account key, which never leaves the server
Forge a "payment successful" webhook	HMAC signature verification rejects any payload not signed with the real Razorpay/Shiprocket secret
Steal a session via an XSS payload	Session cookie is httpOnly -- inaccessible to any JavaScript, injected or not
Script thousands of OTP requests to run up an SMS bill	reCAPTCHA / App Check plus Firebase's own per-number and per-project throttling
Upload an executable disguised as a product photo	Storage rules reject anything whose contentType isn't image/* and cap file size
Replay an old, since-corrected inventory Excel file	Every import is logged to stockLogs with a timestamp -- a bad import is visible and reversible, not silent
Read the Anthropic or Razorpay secret key from the page source	Neither is ever assigned to a NEXT_PUBLIC_ variable or referenced in client code

07

DPDP Act, 2023 — what it requires here

India's Digital Personal Data Protection Act applies to any business collecting personal data from Indian customers — name, phone, address and payment metadata all qualify. Practically, that means:

- **Clear notice** of what is collected and why, in plain language -- the Privacy Policy in section 09 is written to satisfy this.
- **Purpose limitation** -- phone numbers collected for delivery are not repurposed for marketing without separate consent.
- **A named grievance officer** with a real contact address, published on the Privacy Policy, for anyone who wants their data corrected or deleted.
- **Reasonable security safeguards** -- sections 02-06 of this document are what "reasonable" means in practice for a store this size.
- **Breach notification** -- if customer data is ever exposed, affected users and the Data Protection Board must be notified; worth deciding who makes that call before it is ever needed, not during an incident.

08

Terms & Conditions — template

Fill in before publishing

Every [bracket] below needs your real business details. This is a solid starting draft, not a substitute for a lawyer's review before it governs real transactions.

Raj Raani Collections — Terms & Conditions

Last updated: [Date]. These Terms govern all purchases made on [website domain], operated by [Business Legal Name], registered at [Registered Business Address], GSTIN [GSTIN if applicable].

1. **Orders.** Placing an order is an offer to buy; a contract is formed only once we confirm the order (by email, WhatsApp, or on-screen confirmation) and, for prepaid orders, payment is captured.
2. **Pricing.** All prices are in Indian Rupees and inclusive of applicable GST unless stated otherwise. We reserve the right to correct a genuine pricing error before an order is confirmed; if it is discovered after confirmation, we will contact you with the option to proceed at the correct price or cancel for a full refund.
3. **Product representation.** Photography is a close representation of each piece; because many pieces are hand-embroidered, minor variation in color, sheen, or embellishment placement between the photograph and the delivered item is normal, not a defect.
4. **Custom / made-to-order pieces.** Orders marked Custom or Made-to-Measure are produced to the measurements and specifications agreed at the time of order and are non-cancellable once production begins, except as described in the Cancellation & Refund Policy.
5. **Intellectual property.** All product photography, descriptions and site content belong to [Business Legal Name] and may not be reproduced without written permission.
6. **Limitation of liability.** Our liability for any order is limited to the value of that order. We are not liable for delays caused by the courier, force majeure, or incorrect delivery details supplied by the customer.

7. **Governing law.** These Terms are governed by the laws of India, with courts in [City, State] having exclusive jurisdiction.
8. **Contact.** Questions about these Terms: [support email] · [support phone].

09

Privacy Policy — template

Raj Raani Collections — Privacy Policy

Last updated: [Date]. This Policy explains what personal data we collect, why, and the rights you have over it under India's Digital Personal Data Protection Act, 2023.

What we collect

- Name, phone number, email and delivery address, to fulfil an order
- Payment metadata (transaction ID, payment status) from Razorpay -- we never receive or store your card, UPI PIN, or full bank details
- Account credentials, handled entirely by Firebase Authentication
- Conversation text if you use the AI shopping assistant, to answer your question and improve the assistant

Who it is shared with, and why

- **Firebase / Google Cloud** -- hosts our database, authentication and file storage
- **Razorpay** -- processes payments; card and bank details are handled entirely on their PCI-compliant systems, never ours
- **Shiprocket** and its courier partners -- receive your name, phone and address solely to deliver your order
- **Anthropic** -- processes messages sent to the AI shopping assistant
- We do not sell personal data to anyone, for any reason.

Your rights

You may request access to, correction of, or deletion of your personal data at any time by contacting our grievance officer below. We will respond within the timeframe required by applicable law.

Grievance officer

[Grievance Officer Name] · [email] · [postal address] · [phone]

10

Shipping & Delivery Policy — template

Raj Raani Collections — Shipping & Delivery Policy

India only

We currently ship within India exclusively. We do not offer international delivery at this time.

1. **Delhi NCR:** most in-stock orders are delivered in 1-2 days via our hyperlocal courier partner.
2. **Rest of India:** in-stock orders are delivered in 3-7 business days, depending on the destination pincode and the courier assigned.
3. **Custom / made-to-order pieces** ship only once production is complete, per the lead time stated on that product's page -- this is in addition to, not instead of, the delivery time above.
4. **Delivery charges** are shown at checkout before payment and are waived above our current free-delivery threshold, shown in the cart.
5. **Heavy or bulky pieces** (most bridal lehengas) may carry a freight surcharge, also shown at checkout, never added after the fact.
6. A tracking link is provided by SMS/WhatsApp and on the order page once an order is dispatched. Delivery estimates are our best expectation, not a guarantee, and can be affected by courier delays, weather or circumstances outside our control.

11

Cancellation & Refund Policy — template

Raj Raani Collections — Cancellation, Return & Refund Policy

1. **Cancellation window.** An order on a ready-to-ship item can be cancelled free of charge any time before it is marked Shipped. A custom / made-to-order piece can be cancelled only before production begins; once production starts, the advance payment is non-refundable.
2. **Returns.** Ready-to-ship items may be returned within 7 days of delivery if unused, unaltered, and with tags intact. Custom / made-to-measure pieces are **not eligible for return**, as they are produced specifically to the customer's order -- this is stated on the product page before purchase.
3. **Damaged or incorrect items.** Report a damaged, defective or incorrect item within 48 hours of delivery, with photographs, to [support email/WhatsApp]. We cover return shipping in this case and offer a replacement or full refund.
4. **Refund method & timeline.** Approved refunds are issued to the original payment method within 7-10 business days of the returned item passing inspection. Cash on Delivery refunds are processed via bank transfer or UPI.
5. **Exchanges.** A size or color exchange, where stock allows, follows the same window and condition as a standard return.

Security Rules & Compliance Document

The complete access-control rules, a production security checklist, and the four legal pages Raj Raani Collections needs live before a payment gateway or a customer will trust it.

Brand	Raj Raani Collections
Covers	Firestore & Storage rules, password/OTP security, threat checklist, DPDP Act, Terms, Privacy, Shipping, Refund
Before publishing	Sections 08–11 are templates — fill every [bracket] and have them checked by a professional before they go live

01

How security actually works here

There is no separate "security layer" bolted onto the app — access control lives in two rule files that Firestore and Cloud Storage enforce on every single request, whether it comes from the app, a browser's dev console, or an attacker who found the public API config. The rule, stated once: **deny by default, then open exactly what is needed**. Every collection below is either public-read, owner-only, or admin-only — nothing is left at its permissive default.

02

Firestore Security Rules — complete

```

rules_version = '2';
service cloud.firestore {
  match /databases/{database}/documents {

    function isAdmin() {
      return request.auth != null && request.auth.token.admin == true;
    }
    function isOwner(uid) {
      return request.auth != null && request.auth.uid == uid;
    }
    function isSignedIn() {
      return request.auth != null;
    }

    // Catalog -- public read, admin write
    match /categories/{id}      { allow read: if true; allow write: if isAdmin(); }
    match /products/{id}       { allow read: if true; allow write: if isAdmin(); }
    match /productVariants/{id} { allow read: if true; allow write: if isAdmin(); }

    // Per-user data -- owner or admin only, nested subcollections inherit
    match /users/{uid} {
      allow read, write: if isOwner(uid) || isAdmin();
      match /{sub=**} {
        allow read, write: if isOwner(uid);
      }
    }

    // Orders -- the owning customer can read their own; only the
    // server (Admin SDK, via Server Actions) or an admin can write
    match /orders/{id} {
      allow read: if isAdmin() ||
        (isSignedIn() && resource.data.userId == request.auth.uid);
      allow create: if true; // guest checkout -- validated server-side
      allow update: if isAdmin();
      allow delete: if false; // orders are never deleted, only cancelled
    }

    // Audit trails -- admin only, and never editable once written
    match /stockLogs/{id} {
      allow read: if isAdmin();
      allow create: if isAdmin();
      allow update, delete: if false;
    }
  }
}

```

```

    }

    // Assistant transcripts -- anyone can append to their own session,
    // only the admin can read them back
    match /assistantLogs/{id} {
      allow read: if isAdmin();
      allow create: if true;
      allow update, delete: if false;
    }

    // Deny everything else explicitly
    match /{document=**} {
      allow read, write: if false;
    }
  }
}

```

03

Cloud Storage Security Rules

```

rules_version = '2';
service firebase.storage {
  match /b/{bucket}/o {

    // Product photos -- public read, admin write, images only, size-capped
    match /products/{allPaths=**} {
      allow read: if true;
      allow write: if request.auth != null
        && request.auth.token.admin == true
        && request.resource.size < 5 * 1024 * 1024
        && request.resource.contentType.matches('image/.*');
    }

    // Category banners -- same pattern
    match /categories/{allPaths=**} {
      allow read: if true;
      allow write: if request.auth != null
        && request.auth.token.admin == true
        && request.resource.size < 5 * 1024 * 1024
        && request.resource.contentType.matches('image/.*');
    }

    // Deny everything else explicitly
    match /{allPaths=**} {
      allow read, write: if false;
    }
  }
}

```

Redeploy after every change

Rules are not synced automatically from app code. After any change to either file: `firebase deploy --only firestore:rules,storage:rules`. Test changes against the Firebase emulator's rules unit-testing tools before deploying to production — a rules bug fails silently as "permission denied" in the app, which is easy to misdiagnose as an app bug instead.

04

Password & OTP security

CONTROL	SETTING
Minimum password length	8 characters minimum -- Firebase's default of 6 is too weak; raise it in Authentication -> Settings -> Password Policy
Password complexity	Require at least one uppercase, one lowercase and one number via the same Password Policy screen
OTP delivery	Firebase-managed SMS with invisible reCAPTCHA; add Firebase App Check to block scripted OTP-request abuse
OTP expiry	Firebase-issued codes are single-use and time-limited by default -- do not build a custom, longer-lived code
Session length	Customer session cookies: 7-14 days. Admin session cookies: 24-72 hours, with re-authentication required before a destructive action like a bulk delete
Account recovery	Firebase Auth's own reset-email flow only -- never a custom 'security question' fallback, which is weaker, not stronger
Brute-force protection	Firebase Auth throttles repeated failed sign-ins automatically; App Check adds a second layer against scripted attempts

05

Production security checklist

Access control

- Firestore and Storage rules deployed exactly as in sections 02-03, tested against the emulator, not just "looks right"
- Admin access granted only via a custom claim set server-side -- never a client-writable field
- Every admin route re-checked in Next.js middleware on every request, not cached client-side

Secrets

- No secret, ever, in a `NEXT_PUBLIC_` variable -- audited against the table in the Backend & Authentication Document
- Service-account JSON and `.env` files listed in `.gitignore` before the first commit
- Firebase App Hosting environment configuration is the only place production secrets are typed in

Input & sessions

- Every Server Action validates its input with a schema (Zod) before touching Firestore
- Session cookies are httpOnly, secure, sameSite -- confirmed with browser dev tools, not assumed
- Rate limits in place on sign-in, checkout, the Excel import, and the AI assistant

Payments & webhooks

- No card or bank detail ever stored on this server -- Razorpay's hosted Checkout.js handles all of it
- Razorpay and Shiprocket webhook signatures verified before any payload is acted on
- Payment status changes only through a verified webhook or a signature-checked callback, never a plain client POST

Monitoring & recovery

- Firestore scheduled exports to Cloud Storage turned on, and a restore actually tested once
- Firebase console and App Hosting logs checked weekly for repeated auth failures or error spikes
- A named person (even if it's just the owner) knows what to do first if a customer reports account or payment fraud

06

Can this be hacked? — threat to mitigation

IF SOMEONE TRIES TO...	WHAT STOPS THEM
Read another customer's address or order	Firestore rules check resource.data.userId against the caller's own auth token -- enforced by Firestore itself, not app code that could have a bug
Grant themselves the admin role	Custom claims can only be set by code holding the service-account key, which never leaves the server
Forge a "payment successful" webhook	HMAC signature verification rejects any payload not signed with the real Razorpay/Shiprocket secret
Steal a session via an XSS payload	Session cookie is httpOnly -- inaccessible to any JavaScript, injected or not
Script thousands of OTP requests to run up an SMS bill	reCAPTCHA / App Check plus Firebase's own per-number and per-project throttling
Upload an executable disguised as a product photo	Storage rules reject anything whose contentType isn't image/* and cap file size
Replay an old, since-corrected inventory Excel file	Every import is logged to stockLogs with a timestamp -- a bad import is visible and reversible, not silent
Read the Anthropic or Razorpay secret key from the page source	Neither is ever assigned to a NEXT_PUBLIC_ variable or referenced in client code

07

DPDP Act, 2023 — what it requires here

India's Digital Personal Data Protection Act applies to any business collecting personal data from Indian customers — name, phone, address and payment metadata all qualify. Practically, that means:

- **Clear notice** of what is collected and why, in plain language -- the Privacy Policy in section 09 is written to satisfy this.
- **Purpose limitation** -- phone numbers collected for delivery are not repurposed for marketing without separate consent.
- **A named grievance officer** with a real contact address, published on the Privacy Policy, for anyone who wants their data corrected or deleted.
- **Reasonable security safeguards** -- sections 02-06 of this document are what "reasonable" means in practice for a store this size.
- **Breach notification** -- if customer data is ever exposed, affected users and the Data Protection Board must be notified; worth deciding who makes that call before it is ever needed, not during an incident.

08

Terms & Conditions — template

Fill in before publishing

Every [bracket] below needs your real business details. This is a solid starting draft, not a substitute for a lawyer's review before it governs real transactions.

Raj Raani Collections — Terms & Conditions

Last updated: [Date]. These Terms govern all purchases made on [website domain], operated by [Business Legal Name], registered at [Registered Business Address], GSTIN [GSTIN if applicable].

1. **Orders.** Placing an order is an offer to buy; a contract is formed only once we confirm the order (by email, WhatsApp, or on-screen confirmation) and, for prepaid orders, payment is captured.
2. **Pricing.** All prices are in Indian Rupees and inclusive of applicable GST unless stated otherwise. We reserve the right to correct a genuine pricing error before an order is confirmed; if it is discovered after confirmation, we will contact you with the option to proceed at the correct price or cancel for a full refund.
3. **Product representation.** Photography is a close representation of each piece; because many pieces are hand-embroidered, minor variation in color, sheen, or embellishment placement between the photograph and the delivered item is normal, not a defect.
4. **Custom / made-to-order pieces.** Orders marked Custom or Made-to-Measure are produced to the measurements and specifications agreed at the time of order and are non-cancellable once production begins, except as described in the Cancellation & Refund Policy.
5. **Intellectual property.** All product photography, descriptions and site content belong to [Business Legal Name] and may not be reproduced without written permission.
6. **Limitation of liability.** Our liability for any order is limited to the value of that order. We are not liable for delays caused by the courier, force majeure, or incorrect delivery details supplied by the customer.

7. **Governing law.** These Terms are governed by the laws of India, with courts in [City, State] having exclusive jurisdiction.
8. **Contact.** Questions about these Terms: [support email] · [support phone].

09

Privacy Policy — template

Raj Raani Collections — Privacy Policy

Last updated: [Date]. This Policy explains what personal data we collect, why, and the rights you have over it under India's Digital Personal Data Protection Act, 2023.

What we collect

- Name, phone number, email and delivery address, to fulfil an order
- Payment metadata (transaction ID, payment status) from Razorpay -- we never receive or store your card, UPI PIN, or full bank details
- Account credentials, handled entirely by Firebase Authentication
- Conversation text if you use the AI shopping assistant, to answer your question and improve the assistant

Who it is shared with, and why

- **Firebase / Google Cloud** -- hosts our database, authentication and file storage
- **Razorpay** -- processes payments; card and bank details are handled entirely on their PCI-compliant systems, never ours
- **Shiprocket** and its courier partners -- receive your name, phone and address solely to deliver your order
- **Anthropic** -- processes messages sent to the AI shopping assistant
- We do not sell personal data to anyone, for any reason.

Your rights

You may request access to, correction of, or deletion of your personal data at any time by contacting our grievance officer below. We will respond within the timeframe required by applicable law.

Grievance officer

[Grievance Officer Name] · [email] · [postal address] · [phone]

10

Shipping & Delivery Policy — template

Raj Raani Collections — Shipping & Delivery Policy

India only

We currently ship within India exclusively. We do not offer international delivery at this time.

1. **Delhi NCR:** most in-stock orders are delivered in 1-2 days via our hyperlocal courier partner.
2. **Rest of India:** in-stock orders are delivered in 3-7 business days, depending on the destination pincode and the courier assigned.
3. **Custom / made-to-order pieces** ship only once production is complete, per the lead time stated on that product's page -- this is in addition to, not instead of, the delivery time above.
4. **Delivery charges** are shown at checkout before payment and are waived above our current free-delivery threshold, shown in the cart.
5. **Heavy or bulky pieces** (most bridal lehengas) may carry a freight surcharge, also shown at checkout, never added after the fact.
6. A tracking link is provided by SMS/WhatsApp and on the order page once an order is dispatched. Delivery estimates are our best expectation, not a guarantee, and can be affected by courier delays, weather or circumstances outside our control.

11

Cancellation & Refund Policy — template

Raj Raani Collections — Cancellation, Return & Refund Policy

1. **Cancellation window.** An order on a ready-to-ship item can be cancelled free of charge any time before it is marked Shipped. A custom / made-to-order piece can be cancelled only before production begins; once production starts, the advance payment is non-refundable.
2. **Returns.** Ready-to-ship items may be returned within 7 days of delivery if unused, unaltered, and with tags intact. Custom / made-to-measure pieces are **not eligible for return**, as they are produced specifically to the customer's order -- this is stated on the product page before purchase.
3. **Damaged or incorrect items.** Report a damaged, defective or incorrect item within 48 hours of delivery, with photographs, to [support email/WhatsApp]. We cover return shipping in this case and offer a replacement or full refund.
4. **Refund method & timeline.** Approved refunds are issued to the original payment method within 7-10 business days of the returned item passing inspection. Cash on Delivery refunds are processed via bank transfer or UPI.
5. **Exchanges.** A size or color exchange, where stock allows, follows the same window and condition as a standard return.